

Nmap 完整指南

从入门到进阶——中文说明

教育与合法使用提示

本指南仅用于教育和学习。Nmap

只能用于自己的设备/网络，或在获得明确合法授权的情况下使用。未经许可扫描他人网络可能违法。

目录

1. Nmap 是什么以及为什么使用
2. 安装 Nmap
3. 基本扫描命令
4. 端口扫描类型
5. 主机发现命令
6. 扫描时间与速度
7. 操作系统与版本检测
8. Nmap 脚本引擎（NSE）
9. 保存输出格式
10. 防火墙/IDS 绕过选项
11. 常用组合与实例
12. 快速参考
13. 道德与法律事项

1. Nmap 是什么？

Nmap（Network Mapper）是免费的开源网络扫描工具。它可以收集计算机、路由器、手机或服务器的信息，例如设备是否在线、哪些端口开放、哪些服务正在运行，以及有时使用的操作系统。

可以把 IP 地址想象成一栋建筑，把端口想象成建筑的许多门。Nmap 会检查这些门是否打开，以及开放的门后面运行着什么服务。

常见用途

- 网络管理员监控自己的网络。
- 安全专业人员进行获得授权的安全测试。
- 学生在自己的实验环境学习网络安全。
- 系统管理员检查是否存在不需要的服务。

2. 安装 Nmap

Kali Linux 通常已经安装 Nmap。

```
nmap --version
```

```
sudo apt update
```

```
sudo apt install nmap -y
```

第一条命令检查版本；后两条用于更新软件包信息并安装 Nmap。

3. 基本扫描

```
nmap <target>
```

默认检查最常见的 1000 个端口。

```
nmap <network>/24
```

/24 最多可覆盖 256 个 IP 地址，只应在获得授权的网络中使用。

```
nmap 10.0.0.1 10.0.0.2 10.0.0.3
```

```
nmap 10.0.0.1-50
```

用于扫描多个目标或一个 IP 范围。

4. 端口扫描类型

TCP Connect：

```
nmap -sT <target>
```

完成正常 TCP 连接，通常不需要 root/admin，但速度可能较慢且日志中更明显。

SYN Scan：

```
sudo nmap -sS <target>
```

开始 TCP 连接但不完成连接，通常更快，并通常需要 root/sudo 权限。

UDP Scan：

```
sudo nmap -sU <target>
```

检查 UDP 端口，例如 DNS、DHCP 使用的端口；通常比 TCP 扫描慢。

指定端口：

```
nmap -p 22,80,443 <target>
```

```
nmap -p 1-100 <target>
```

```
nmap -p- <target>
```

最后一条扫描全部 65,535 个 TCP 端口。

快速扫描：

```
nmap -F <target>
```

只检查最常见的 100 个端口。

5. 主机发现

```
nmap -sn <target>/24
```

只进行主机发现，用于快速寻找在线设备。

```
nmap -Pn <target>
```

跳过 ping/主机发现，直接尝试扫描；当防火墙阻止 ping 时可能有用。

6. 扫描速度

-T0 Paranoid——非常慢

-T1 Sneaky——较慢

-T2 Polite——较少使用带宽

-T3 Normal——默认

-T4 Aggressive——较快

-T5 Insane——最快，但可能遗漏结果

`nmap -T4 <target>`

7. OS 与版本检测

`nmap -sV <target>`

尝试识别开放端口上的软件及其版本。

`sudo nmap -O <target>`

根据网络响应估计操作系统，不保证 100% 准确。

`sudo nmap -A <target>`

同时启用 OS、版本、脚本和 traceroute 检测，信息更详细且可能更慢。

8. NSE

Nmap 自带许多脚本，可检查漏洞、配置错误和其他信息。

`nmap -sC <target>`

`nmap --script=<script-name> <target>`

`nmap --script=http-title <target>`

`nmap --script=vuln <target>`

vuln 类别用于检查已知漏洞，只能对获得授权的目标使用。

9. 保存输出

`nmap -oN result.txt <target>`

`nmap -oX result.xml <target>`

`nmap -oG result.gnmap <target>`

`nmap -oA result <target>`

分别保存 Normal、XML、Grepable，或一次保存三种格式。

10. 防火墙/IDS 绕过

本节仅用于获得授权的渗透测试概念学习。

`nmap -f <target>`

将数据包进行分片。

`nmap -D RND:5 <target>`

加入五个随机诱饵地址。

```
nmap --data-length 25 <target>
```

向数据包加入额外数据。未经授权不要使用规避功能。

11. 常用组合

```
sudo nmap -sS -sV -O -p- -T4 <target>
```

```
nmap -sn <network>/24
```

```
nmap -p 80,443 -sV --script=http-title <target>
```

```
nmap -T4 -F <target>
```

12. 快速参考

`nmap <target>` — 基本扫描

`nmap -sn <target>` — 主机发现

`nmap -p- <target>` — 全部端口

`nmap -sV <target>` — 服务版本

`nmap -O <target>` — OS 检测

`nmap -A <target>` — 详细扫描

`nmap -T4 <target>` — 更快速度

`nmap -Pn <target>` — 跳过 ping

`nmap -sC <target>` — 默认脚本

`nmap -oN file.txt <target>` — 保存结果

13. 道德与法律

只扫描自己的设备和网络。测试其他网络前应取得书面授权。许多国家/地区未经授权的网络扫描可能违反网络安全法律，即使没有造成损害。学习时可使用 TryHackMe 和 Hack The Box 等授权实验环境。本指南仅用于教育目的。